Cryptography for Secure communication

6COSC019W- Cyber Security

Usama Arusi

March 16, 2026

Prepared by Dr Ayman El Hajjar

UNIVERSITY OF WESTMINSTER

Overview

1. Security Controls

2. Application layer controls

3. Host to Host/Transport layer Controls

4. Network Layer Controls

Security Control

Control is defined as:

"An action, device, procedure, or other measure that reduces risk by eliminating or preventing a security violation, by minimizing the harm it can cause, or by discovering and reporting it to enable corrective action."

Control Classifications

- Management controls
  - Focus on security policies, planning, guidelines, and standards that influence the selection of operational and technical controls to reduce the risk of loss and to protect the organization's mission
  - These controls refer to issues that management needs to address
- Operational controls
  - Address the correct implementation and use of security policies and standards, ensuring consistency in security operations and correcting identified operational deficiencies
  - These controls relate to mechanisms and procedures that are primarily implemented by people rather than systems
  - They are used to improve the security of a system or group of systems

Control Classifications

- Technical controls
  - Involve the correct use of hardware and software security capabilities in systems
  - These range from simple to complex measures that work together to secure critical and sensitive data, information, and IT systems functions

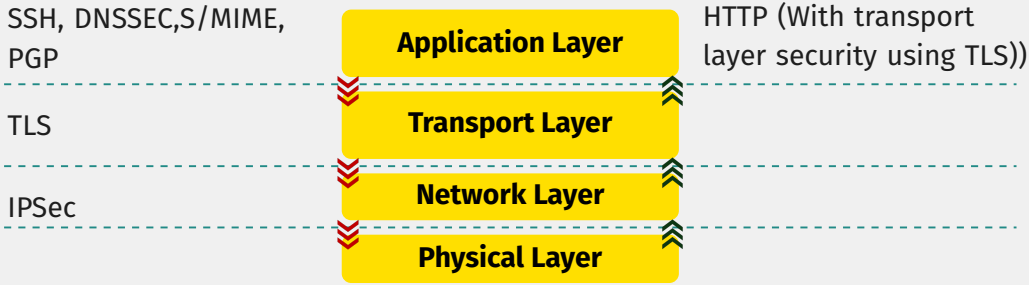
Control Classes

Each of the control classes may include the following:

- Supportive controls
  - Pervasive, generic, underlying technical IT security capabilities that are interrelated with, and used by, many other controls
- Preventative controls
  - Focus on preventing security breaches from occurring, by inhibiting attempts to violate security policies or exploit a vulnerability
- Detection and recovery controls
  - Focus on the response to a security breach, by warning of violations or attempted violations of security policies or the identified exploit of a vulnerability and by providing means to restore the resulting lost computing resources

Technical controls Example- TCP/IP security solution

- Different security approaches can be applied to secure communication using various security protocols.
- Each protocol provides security at a specific layer of the TCP/IP stack.
- Security solutions often combine multiple security protocols at different layers to strengthen the overall communication protection.



Secure/Multipurpose Internet Mail Extension

- Security enhancement to the Multipurpose Internet Mail Extension MIME Internet e-mail format
- Based on technology from RSA Data Security
- Provides the ability to sign and/or encrypt e-mail messages
- Uses a centralised PKI (Public Key Infrastructure) with certificates issued by trusted Certificate Authorities (CAs)
- Uses centrally managed certificates for email encryption and digital signatures
- More commonly used in enterprises and corporate email systems
- Built into many email clients like Outlook, Thunderbird, and Apple Mail

S/MIME Functions

Enveloped Data

Encrypted content and associated keys: Encrypted content and encrypted-content encryption keys for one or more recipients.

Signed data

Encoded message + signed digest: A signature is formed from the message digest, encrypted with the signer's private key, then base64 encoded.

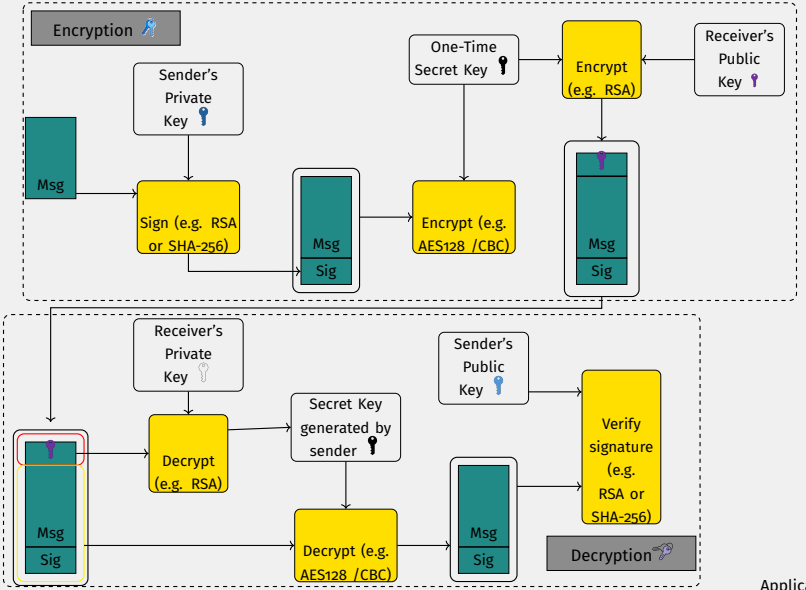
Clear-signed data

Cleartext message + encoded signed digest: The content remains readable, but the signature is base64 encoded, so non-S/MIME recipients can read it but cannot verify it.

Signed & enveloped

Signed-only and encrypted-only entities may be nested, so signed data may be encrypted and encrypted data may be signed.

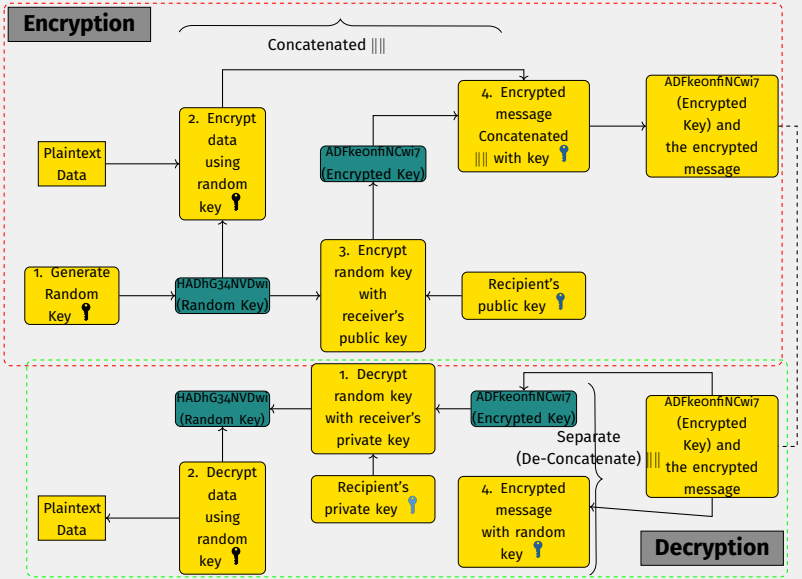
S/MIME Functional flow



Pretty Good Privacy (PGP)

- Popular program used to encrypt and decrypt e-mail and files
- Uses a web of trust where users manually verify and trust each other's keys
  - Requires manual key exchange and trust establishment
- Use a Public Private Keys (PPK) method
  - An individual (creator) uses the encryption program to create a random key
    - Symmetric encryption algorithm uses the random key to encrypt the message
    - Symmetric (random) key is encrypted with the public key of the recipient and the encrypted key is sent with the message
  - Receiver's PGP software decrypts the symmetric key and then uses it to decrypt the message
  - More flexible and decentralised than S/MIME but less scalable

PGP Encryption and Decryption process



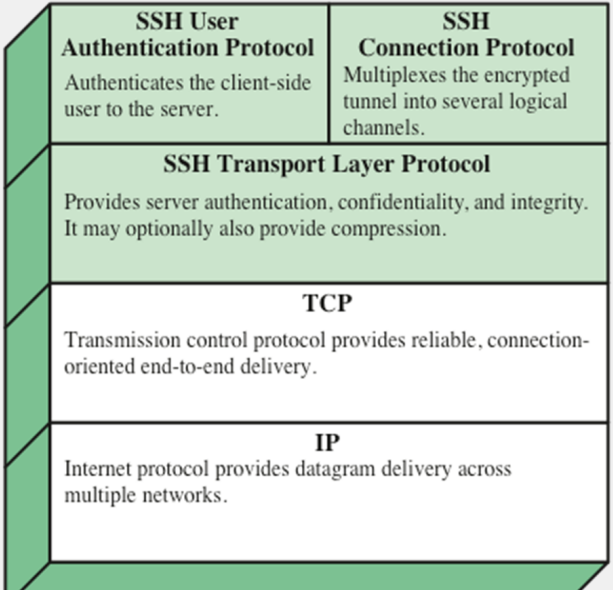
DNS threats Prevention

- To prevent DNS Hijacking and DNS Pharming, DNS Security (DNSSEC) is deployed to ensure:
  - Authenticity of DNS answer origin
  - Integrity of reply
  - Authenticity of denial of existence
  - Accomplishes this by signing DNS replies at each step of the way
  - Uses public-key cryptography to sign responses
- DNSSEC adds considerable load to dns servers with packet sizes considerably larger than 512 byte size of UDP packets

Secure Shell (SSH)

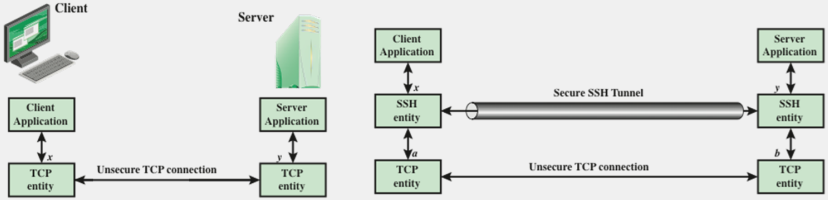
- A protocol for secure network communications designed to be relatively simple and inexpensive to implement
- The initial version, SSH1 was focused on providing a secure remote logon facility to replace TELNET and other remote login schemes that provided no security
- In addition to secure remote login, SSH2 also provides more capabilities such as network functions like file transfer and secure shell tunnelling for e-mail
- SSH client and server applications are widely available for most operating systems
- SSH2 fixes a number of security flaws in the original scheme, particularly encryption flaws that enabled Man-in-the-Middle attacks.

SSH PROTOCOL STACK



TCP over SSH message

- First, the client establishes a TCP connection to the server.
  - This is done via the TCP protocol and is not part of the SSH Transport Layer Protocol.
- Once a TCP connection is established, the SSH protocol starts the secure connection establishment by enabling the **SSH Transport Layer Protocol** to provide server authentication, confidentiality, and integrity of the data.



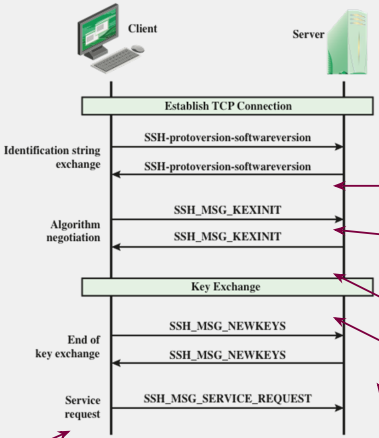
(a) Connection via TCP

(b) Connection via SSH Tunnel

SSH PROTOCOL STACK

- The SSH Transport layer protocol provides the mechanism to establish the secure connection this using two distinct functions (or protocols):
  - The **SSH User Authentication Protocol** is responsible for verifying the identity of the client (user) to the server. This protocol ensures that only authorised users gain access to the server.
  - The **SSH Connection Protocol** establishes and manages a secure communication channel between the client and server. Once authenticated, this protocol handles the secure transfer of data.

SSH PROTOCOL STACK



This is the initial step where a TCP connection is established between the client and the server.

The Identification String Exchange Phase is the first phase of initiating the handshake. The client and server exchanges their identification strings. .

```
SSH-2.0-OpenSSH_7.6p1 Ubuntu-4ubuntu0.3
```

In the Key Algorithm Negotiation phase, the client and server exchange messages to agree on which cryptographic algorithms to use for the session. .

In the Key Exchange phase, the client send the random key generated from the pre shared keys, encrypoted using the server public key. The server verify the key and responds that it was able to decrypt it.

In the End of key exchange phase the client and server completes the key exchanghe phase by sending the hashed value of the session key so that the server verifies one more time that the session key is correct.

In the Secure Request the client formally begins secure communication with the server by sending an encrypted message using the session key that includes information such as the date and time the communication started.

Transport Layer Security

- One of the most widely used security services, mostly with a method of interacting with a public key infrastructure (PKI) and certificates
- When utilising the TCP/IP protocol, TLS is the preferred method of managing transport level security.
- The TLS concept is the following:

  (1) A **TLS Session** is created between a client and a server using the handshake protocol. It defines a set of cryptographic security parameters.

  it is Used to avoid the expensive negotiation of new security parameters

  (2) One the session is created, a **TLS Connection** only for the duration of the communication.

  This is a called a transient Peer-to-peer relationship. Every connection is associated with one session

TLS Components

- The TLS is composed of two protocols:

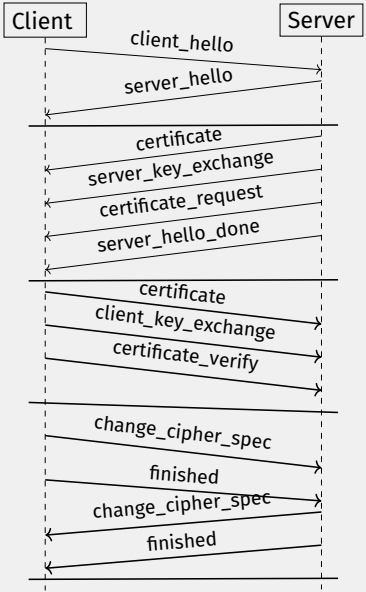
  (1) The **TLS Handshake Protocol**: Comprises a series of messages exchanged by the client and server (over four phases)

  - The most complex part of TLS and is used before any application data are transmitted
  - Allows server and client to: Authenticate Each Other $\rightarrow$ Negotiate encryption and MAC algorithms $\rightarrow$ Negotiate cryptographic keys to be used

  (2) The **TLS Record Protocol**

  - It ensures that data transmitted over a network remains confidential, intact, and untampered (using a combination of hashing and encrypted the secret key).
  - It provides the foundation for secure communication in applications such as web browsing, email, and other internet-based activities.

TLS Handshake keys exchange



Phase 1- Establish Security capabilities, including protocol version, session ID, cipher Suite, Compression method and initial random values.

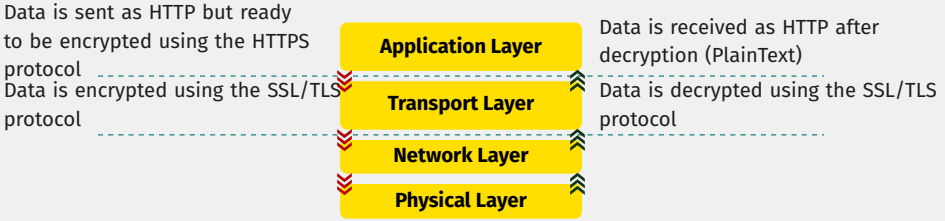
Phase 2- Server sends certificate, key exchange and request certificate. Server signals end with **hello message done** this phase.

Phase 3- Client sends certificate if requested. Client sends key exchange. Client may send certificate verification.

Phase 4- Change cipher suite and finish handshake protocol. (Both the client and server to switch from unencrypted to encrypted communication, using the agreed-upon cipher suite)

HTTP Secure (HTTPS)

- While HTTP itself is used for retrieving web pages and transferring data, HTTPS secures that data to prevent eavesdropping, tampering, and forgery.
- HTTPS is HTTP with TLS encryption added on top. TLS adds a layer of security to encrypt the data being transferred, ensuring that communication is private and secure.
- While HTTPS is typically considered an application layer protocol, it relies on the TLS transport layer for security.



IP Security (IPsec)

Rationale

- IP traffic headers and payloads transmitted over the Internet are not inherently encrypted, making them susceptible to interception and tampering. Therefore, we need a mechanism like IPsec to ensure the confidentiality, integrity, and authenticity of IP traffic.

Security for IP & Networks

- Need to secure the network infrastructure from unauthorised monitoring and control of network traffic
- Need to secure end-user-to-end-user traffic using authentication and encryption mechanisms-

Applications of IPsec

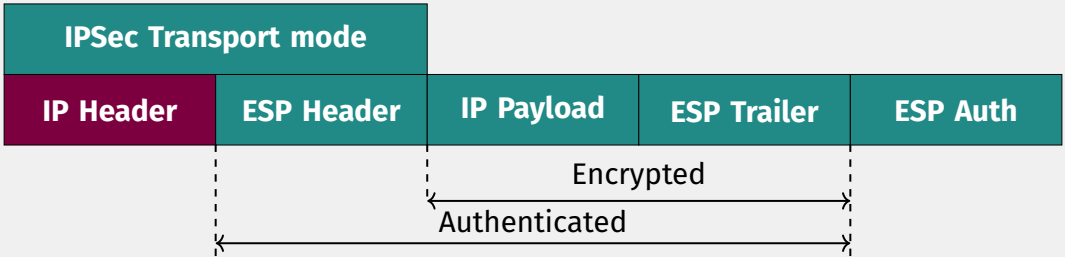
- IPsec provides the capability to secure communications across a LAN, private and public WANs, and the Internet
- Examples include:
  - Secure branch office connectivity over the Internet
  - Secure remote access over the Internet
  - Establishing extranet and intranet connectivity with partners
  - Enhancing electronic commerce security
- Principal feature of IPsec is that it can encrypt and/or authenticate all traffic at the IP level
  - Thus all distributed applications (remote logon, client/server, e-mail, file transfer, Web access) can be secured

IP Security (IPsec)

- By implementing security at the IP level, IPSec ensures that security can be provided even for the many security-ignorant applications.
- IPSec is a collection of IP security features designed to introduce security at the network layer in network communication
  - Data alone (IPSec transport mode)
  - Both the data and header (tunnel mode)
- IP-level security encompasses three functional areas:
  - **Authentication** mechanism assures that a received packet was, in fact, transmitted by the party identified as the source in the packet header and that it has not been altered.
  - **Confidentiality** facility enables communicating nodes by encrypting messages to prevent eavesdropping by 3rd parties.
  - **Key management** facility is concerned with the secure exchange of keys.

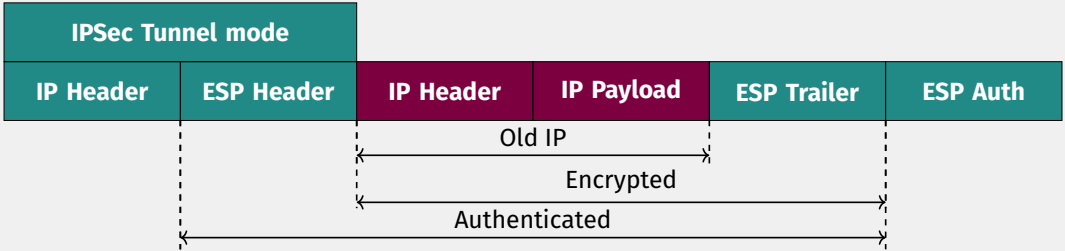
IPSec Transport mode

- Transport mode extends to the payload of an IP packet
- Typically used for end-to-end communication between two hosts
- ESP encrypts and optionally authenticates the IP payload but not the IP header



IPSec Tunnel mode

- Tunnel mode provides protection to the entire IP packet
- The entire original packet travels through a tunnel from one point of an IP network to another
- Used when one or both ends of a security association are a security gateway
- A number of hosts on networks behind firewalls may engage in secure communications without implementing IPsec



Benefits of IPsec

- When implemented in a firewall or router, it provides strong security to all traffic crossing the perimeter
- In a firewall it is resistant to bypass
- Below transport layer, hence transparent to applications
- Can be transparent to end users
- Can provide security for individual users

References

- The lecture notes and contents were compiled from my own notes and from various sources.
- Figures and tables are from the recommended books
- **The lecture notes are very detailed. If you attend the lecture, you should be able to understand the topics.**
- **Recommended Readings note:** Focus on what was covered in the class.
  - Chapter 9- Computer Security Technology, Computer Security Fundamentals